



National Cyber  
Security Centre  
a part of GCHQ

# Cyber Assessment Framework 4.0

The CAF is a collection of cyber security guidance for organisations that play a vital role in the day-to-day life of the UK, with a focus on essential functions.



## Contents

|                                                                                   |           |
|-----------------------------------------------------------------------------------|-----------|
| The CAF – A tool for assessing cyber resilience .....                             | 2         |
| CAF Requirements.....                                                             | 3         |
| CAF Principles and contributing outcomes .....                                    | 3         |
| Using IGPs.....                                                                   | 4         |
| Setting target levels of cyber security and resilience.....                       | 5         |
| Making the CAF sector specific .....                                              | 6         |
| The Cyber Assessment Framework.....                                               | 7         |
| <b>CAF – Objective A – Managing security risk .....</b>                           | <b>7</b>  |
| Principle A1 Governance .....                                                     | 7         |
| Principle A2 Risk Management.....                                                 | 11        |
| Principle A3 Asset Management.....                                                | 17        |
| Principle A4 Supply Chain .....                                                   | 18        |
| <b>CAF – Objective B – Protecting against cyber attack .....</b>                  | <b>23</b> |
| Principle B1 Service Protection Policies, Processes and Procedures.....           | 23        |
| Principle B2 Identity and Access Control.....                                     | 26        |
| Principle B3 Data Security .....                                                  | 32        |
| Principle B4 System Security.....                                                 | 39        |
| Principle B5 Resilient Networks and Systems.....                                  | 45        |
| Principle B6 Staff Awareness and Training.....                                    | 48        |
| <b>CAF – Objective C – Detecting Cyber Security Events.....</b>                   | <b>51</b> |
| Principle C1 Security Monitoring.....                                             | 51        |
| Principle C2 Threat Hunting .....                                                 | 61        |
| <b>CAF – Objective D – Minimising the impact of cyber security incidents.....</b> | <b>63</b> |
| Principle D1 Response and Recovery Planning.....                                  | 63        |
| Principle D2 Lessons Learned.....                                                 | 66        |

**Please Note:** A list of all changes made between CAF V3.2 and V4.0, and all previous versions of the CAF are available on the NCSC website.

## The CAF – A tool for assessing cyber resilience

The Cyber Assessment Framework (CAF) provides a systematic and comprehensive approach to assessing the extent to which cyber risks to essential function(s) are being managed by the organisation responsible. CAF-based assessments can be carried out either by the responsible organisation itself (self-assessment) or by an independent external entity, possibly a regulator / cyber oversight body or a suitably qualified organisation acting on behalf of a regulator, such as an NCSC assured commercial service provider.

The NCSC CAF cyber security and resilience objective and principles provide the foundations of the CAF. The 4 high-level objectives and the 14 principles are written in terms of outcomes, i.e. specification of what needs to be achieved rather than a checklist of what needs to be done. The CAF adds additional levels of detail to the top-level principles, including a collection of structured sets of Indicators of Good Practice (IGPs) as described in more detail below.

It should be noted that NCSC developed the CAF in its role as national technical authority for cyber security, with an expectation that it would be used, amongst other things, as a tool to support effective cyber regulation. NCSC itself has no regulatory responsibilities, and organisations subject to cyber regulation should consult with their regulators to learn whether they should use the CAF in the context of meeting regulatory requirements.

## CAF Requirements

The CAF has been developed to meet the following set of requirements:

1. provide a suitable framework to assist in carrying out cyber resilience assessments.
2. maintain the outcome-focused approach of the NCSC cyber security and resilience principles and discourage assessments being carried out as tick-box exercises.
3. be compatible with the use of appropriate existing cyber security guidance and standards.
4. enable the identification of effective cyber security and resilience improvement activities.
5. exist in a common core version which is sector-agnostic.
6. be extensible to accommodate sector-specific elements as may be required.
7. enable the setting of meaningful target security levels for organisations to achieve, possibly reflecting a regulator view of appropriate and proportionate security.
8. be as straightforward and cost-effective to apply as possible.

## CAF Principles and contributing outcomes

Each top-level NCSC security and resilience principle defines a broad cyber security outcome. The precise approach organisations should adopt to achieve each principle is not specified as this will vary according to organisational circumstances. However, each principle can be broken down into a collection of lower-level contributing cyber security and resilience outcomes, all of which will normally need to be achieved to fully satisfy the top-level principle.

An assessment of the extent to which an organisation is meeting a particular principle is accomplished by assessing all the contributing outcomes for that principle. In order to inform assessments at the level of contributing outcomes:

1. each contributing outcome is associated with a set of indicators of good practice (IGPs) and,
2. using the relevant IGPs, the circumstances under which the contributing outcome is judged 'achieved', 'not achieved' or (in some cases) 'partially achieved' are described.

For each contributing outcome the relevant IGPs have conveniently been arranged into table format. The resulting tables, referred to as *IGP tables*, constitute the basic building

blocks of the CAF. In this way, each principle is associated with several tables of IGPs, one table per contributing outcome.

## Using IGPs

Assessment of contributing outcomes is primarily a matter of expert judgement and the IGPs do not remove the requirement for the informed use of cyber security expertise and sector knowledge. IGPs will usually provide good starting points for assessments but should be used flexibly and in conjunction with the NCSC guidance associated with the top-level cyber security and resilience principles. Conclusions about an organisation's cyber security and resilience should only be drawn after considering additional relevant factors and special circumstances.

The 'achieved' (GREEN) column of an IGP table defines the typical characteristics of an organisation fully achieving that outcome. It is intended that all the indicators would normally be present to support an assessment of 'achieved'. The exception would be when an IGP may not be applicable if there are compensating measures that would meet the requirements of the relevant objective.

The 'not achieved' (RED) column of an IGP table defines the typical characteristics of an organisation not achieving that outcome. It is intended that the presence of any one indicator would normally be sufficient to justify an assessment of 'not achieved'.

When present, the 'partially achieved' (AMBER) column of an IGP table defines the typical characteristics of an organisation partially achieving that outcome. It is also important that the partial achievement is delivering specific worthwhile cyber security and resilience benefits. An assessment of 'partially achieved' should represent more than giving credit for doing something vaguely relevant.

The following table summarises the key points relating to the purpose and nature of IGPs.

|                      | IGPs are...                                                                                                                | IGPs are not...                                                           |
|----------------------|----------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|
| <b>Purpose</b>       | ...intended to help inform expert judgement.                                                                               | ...a checklist to be used in an inflexible assessment process.            |
| <b>Scope</b>         | ...important examples of what an assessor will normally need to consider, which may need to be supplemented in some cases. | ... an exhaustive list covering everything an assessor needs to consider. |
| <b>Applicability</b> | ...designed to be widely applicable across different organisations, but applicability needs to be established.             | ...guaranteed to apply verbatim to all organisations.                     |

## Setting target levels of cyber security and resilience

The result of applying the CAF is 41 individual assessments, each one derived from making a judgement on the extent to which a set of IGPs reflects the circumstances of the organisation being assessed. The CAF has been designed in such a way that a result in which all 41 contributing outcomes were assessed as 'achieved' would indicate a level of cyber security some way beyond the bare minimum 'basic cyber hygiene' level.

A cyber oversight body will need to set target levels of cyber resilience for organisations within their sector. One way of setting these target levels is in relation to the *ability to withstand specified categories of cyber attacks* (e.g. resilience to basic capability attacks, moderate capability attacks etc.) and the CAF has been designed to support this approach via the idea of CAF profiles.

The NCSC has worked with regulators and other organisations with a cyber resilience oversight role on an approach to interpreting CAF output based on identifying those contributing outcomes considered most important to achieve in order to manage security risks to that organisation's essential functions. Those prioritised contributing outcomes would correspond to an initial view of appropriate and proportionate cyber security for that organisation. The subset of contributing outcomes identified as the

most important in this way would represent an example of a CAF profile – something that could be used as the basis for setting a target for organisations to achieve.

In practice a CAF profile consists of a mixture of some contributing outcomes to be met at ‘achieved’, some at ‘partially achieved’ and perhaps some (representing cyber security capabilities not appropriate at the level of the profile) identified as ‘not applicable’.

It is not the responsibility of the NCSC to mandate what represents appropriate and proportionate cyber security and resilience. Any target set for organisations to achieve in terms of CAF results is for the relevant cyber oversight body to define.

## **Making the CAF sector specific**

The common core of the CAF (consisting of objectives, principles, contributing outcomes and indicators of good practice) is sector agnostic in the sense that it is designed to be generally applicable to all organisations responsible for essential functions across all key sectors. It is possible that there will be a need for some sector specific aspects of the CAF, which could include the following:

### **i) Sector-specific CAF Profiles**

Some target profiles may well be sector specific. As mentioned in the section on setting target levels, it will be a decision for the relevant cyber oversight body to put an interpretation on CAF results, which may be from a regulatory perspective.

### **ii) Sector-specific Interpretations of Contributing Outcomes/IGPs**

It may be necessary in some cases for a sector-specific interpretation of contributing outcomes and/or IGPs to better clarify meaning within the sector.

### **iii) Sector-specific Additional Contributing Outcomes/IGPs**

There may be circumstances in which sector-specific cyber security requirements cannot be adequately covered by an interpretation of a generic contributing outcome or IGP. In these cases, an additional sector-specific contributing outcome or IGP may need to be defined.

The NCSC will continue to work with the full range of CAF stakeholders to determine if sector-specific aspects of the CAF are required, and to assist in introducing changes as necessary.

## The Cyber Assessment Framework

### CAF – Objective A – Managing security risk

**Appropriate organisational structures, policies, processes and procedures in place to understand, assess and systematically manage security risks to network and information systems supporting essential functions.**

#### Principle A1 Governance

*The organisation has appropriate management policies, processes and procedures in place to govern its approach to the security of network and information systems.*

##### **A1.a Board Direction**

*You have effective organisational security management led at board level and articulated clearly in corresponding policies.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| <p>The security of network and information systems related to the operation of essential function(s) is not discussed or reported on regularly at board-level.</p> <p>Board-level discussions on the security of network and information systems are based on partial or out-of-date information, without the benefit of expert guidance.</p> <p>The security of network and information systems supporting your essential function(s) are not driven effectively by the direction set at board-level.</p> <p>Senior management or other pockets of the organisation consider themselves exempt from some policies or expect special accommodations to be made.</p> | <p>Your organisation's approach and policy relating to the security of network and information systems supporting the operation of your essential function(s) are owned and managed at board-level. These are communicated, in a meaningful way, to risk management decision-makers across the organisation.</p> <p>Regular board-level discussions on the security of network and information systems supporting the operation of your essential function(s) take place, based on timely and accurate information and informed by expert guidance.</p> <p>There is a board-level individual who has overall accountability for the security of</p> |

|  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <p>network and information systems and drives regular discussion at board-level.</p> <p>Direction set at board-level is translated into effective organisational practices that direct and control the security of network and information systems supporting your essential function(s).</p> <p>The board has the information and understanding needed in order to effectively discuss how the security and resilience of network and information systems contributes to the delivery of essential function(s) and what the potential impact from compromise of those systems would be.</p> <p>Security is recognised as an important enabler for the resilience of your essential function(s) and considered in all relevant discussions.</p> |
|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

**A1.b Roles and Responsibilities**

*Your organisation has established roles and responsibilities for the security of network and information systems at all levels, with clear and well-understood channels for communicating and escalating risks.*

| Not Achieved                                                                                                                                                                                                                                                                                                   | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                               | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| <p>Key roles are missing, left vacant, or fulfilled on an ad-hoc or informal basis.</p> <p>Staff are assigned security responsibilities but without adequate authority or resources to fulfil them.</p> <p>Staff are unsure what their responsibilities are for the security of the essential function(s).</p> | <p>Key roles and responsibilities for the security of network and information systems supporting your essential function(s) have been identified. These are reviewed regularly to ensure they remain fit for purpose.</p> <p>Appropriately capable and knowledgeable staff fill those roles and are given the time, authority, and resources to carry out their duties.</p> <p>There is clarity on who in your organisation has overall accountability for the security of network and information systems supporting your essential function(s).</p> |

**A1.c Decision-making**

*You have senior-level accountability for the security of network and information systems, and delegate decision-making authority appropriately and effectively. Risks to network and information systems related to the operation of your essential function(s) are considered in the context of other organisational risks.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| <p>What should be relatively straightforward risk decisions are constantly referred up the chain, or not made.</p> <p>Risks are resolved informally (or ignored) at a local level when the use of a more formal risk reporting mechanism would be more appropriate.</p> <p>Decision-makers are unsure of what senior management's risk appetite is, or only understand it in vague terms such as "averse" or "cautious".</p> <p>Decision-makers are unable to justify their risk management decisions.</p> <p>Organisational structure causes risk decisions to be made in isolation. (e.g. engineering and IT do not talk to each other about risk).</p> <p>Risk priorities are too vague to make meaningful distinctions between them. (e.g. almost all risks are rated 'medium' or 'amber').</p> | <p>Senior management have visibility of key risk decisions made throughout the organisation.</p> <p>Risk management decision-makers understand their responsibilities for making effective and timely decisions in the context of the risk appetite regarding the essential function(s), as set by senior management.</p> <p>Risk management decision-making is delegated and escalated where necessary, across the organisation, to people who have the skills, knowledge, tools and authority they need.</p> <p>Risk management decisions are regularly reviewed to ensure their continued relevance and validity.</p> |

## Principle A2 Risk Management

*The organisation takes appropriate steps to identify, assess and understand security risks to network and information systems supporting the operation of essential functions. This includes an overall organisational approach to risk management.*

### A2.a Risk Management Process

*Your organisation has effective internal processes for managing risks to the security and resilience of network and information systems related to the operation of your essential function(s) and communicating associated activities.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| <p>Risk assessments are not based on a clearly defined set of threat assumptions.</p> <p>Risk assessment outputs are too complex or unwieldy to be consumed by decision-makers and are not effectively communicated in a clear and timely manner.</p> <p>Risk assessments for network and information systems supporting your essential function(s) are a "one-off" activity or not done at all.</p> <p>The security elements of projects or programmes are solely dependent on the completion of a risk management assessment without any regard to the outcomes.</p> | <p>Your organisational process ensures that security risks to network and information systems relevant to essential function(s) are identified, analysed, prioritised, and managed.</p> <p>Your risk assessments are informed by an understanding of known and well understood threats and vulnerabilities in network and information systems supporting your essential function(s).</p> <p>The output from your risk management process is a clear set of security requirements that will address the risks in line with your organisational approach to security.</p> <p>Significant conclusions reached in the course of</p> | <p>Your organisational process ensures that security risks to network and information systems relevant to essential function(s) are identified, analysed, prioritised, and managed.</p> <p>Your approach to risk is focused on the possibility of adverse impact to your essential function(s), leading to a detailed understanding of how such impact might arise as a consequence of possible threat actor actions and the security properties of network and information systems supporting your essential function(s).</p> <p>Your risk assessments are based on a clearly understood set of threat assumptions, informed by</p> |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |                                                                                                                                                                                                                                                                                                                                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>There is no systematic process in place to ensure that identified security risks are managed effectively.</p> <p>Systems are assessed in isolation, without consideration of dependencies and interactions with other systems. (e.g. interactions between IT and OT environments).</p> <p>Security requirements and mitigations are arbitrary or are applied from a control catalogue without consideration of how they contribute to the security of network and information systems supporting your essential function(s).</p> <p>Risks remain unresolved on a register for prolonged periods of time awaiting senior decision-making or resource allocation to resolve.</p> | <p>your risk management process are communicated to key security decision-makers and accountable individuals.</p> <p>You conduct risk assessments when significant events potentially affect the essential function(s), such as replacing a system, introducing new or emergent technologies or a change in the cyber security threat.</p> | <p>an up-to-date understanding of threats to network and information systems supporting your essential function(s), your sector and wider national infrastructure.</p> <p>Your risk assessments are informed by an understanding of the vulnerabilities in network and information systems supporting your essential function(s).</p> <p>The output from your risk management process is a clear set of traceable and prioritised security requirements that will address the risks in line with your organisational approach to security.</p> <p>Significant conclusions reached in the course of your risk management process are communicated to key security decision-makers and accountable individuals.</p> <p>Your risk assessments are dynamic and readily updated in the light of relevant changes which may include technical changes to network and information systems supporting your essential function(s), change of use, the introduction of new or</p> |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

|  |  |                                                                                                                                                                                                                                                                                                                                           |
|--|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  |  | <p>emergent technologies or new threat information.</p> <p>The effectiveness of your risk management process is reviewed regularly, and improvements made as required.</p> <p>You anticipate technological developments that could be used to adversely impact network and information systems supporting your essential function(s).</p> |
|--|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## A2.b Understanding Threat

*You understand the capabilities, methods and techniques of threat actors and what network and information systems they may compromise to adversely impact your essential function(s).*

*This information is used to inform security and resilience risk management decisions, adjusting, enhancing or adding security measures to better defend against threats.*

| Not Achieved                                                                                                                                                                                                                                                                                                                          | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                      | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| <p>You are unable to perform threat analysis.</p> <p>You do not understand the threats to network and information systems supporting your essential function(s).</p> <p>You do not have a clearly defined set of threat assumptions.</p> <p>You do not use your understanding of threat to inform your risk management decisions.</p> | <p>You perform threat analysis and understand how common threats apply to network and information systems supporting your essential function(s).</p> <p>You understand common types of cyber attacks, including the methods and techniques, and how these might apply to network and information systems supporting your essential function(s). This understanding is kept up to date.</p> <p>You anticipate what threat actors might target in network and information systems to cause an adverse impact to your essential function(s).</p> <p>Your understanding of threat is informed by common incidents.</p> <p>You apply your understanding of threat to</p> | <p>You perform detailed threat analysis and understand how this applies to network and information systems supporting your essential function(s), in the context of your sector and wider national infrastructure.</p> <p>Your detailed understanding of threat includes the methods and techniques available to capable and well-resourced threat actors and how they could be used systematically against network and information systems supporting your essential function(s).</p> <p>You use appropriate techniques to develop an understanding of network and information systems supporting your essential function(s) from a threat actor's perspective. You anticipate probable attack methods and techniques,</p> |

|  |                                                     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|--|-----------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <p>inform your risk management decision-making.</p> | <p>targets and objectives, and develop plausible scenarios.</p> <p>You understand the different steps a capable and well-resourced threat actor would need to take to reach the probable target(s).</p> <p>You identify and justify what measures can be used at each step to reduce the likelihood of the threat actor reaching the probable target(s) or achieving their objective(s).</p> <p>You maintain a detailed understanding of current threats (e.g. by threat intelligence and proactive research).</p> <p>You apply your detailed understanding of threat to inform your risk management decision-making.</p> <p>You have documented the steps required to undertake detailed threat analysis.</p> |
|--|-----------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

**A2.c Assurance**

*You have gained confidence in the effectiveness of the security of your technology, people, and processes relevant to the operation of network and information systems supporting your essential function(s).*

| Not Achieved                                                                                                                                                                                                                                                                                | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                            | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| <p>A particular product or service is seen as a "silver bullet" and vendor claims are taken at face value.</p> <p>Assurance methods are applied without appreciation of their strengths and limitations.</p> <p>Assurance is assumed because there have been no known problems to date.</p> | <p>You validate that the security measures in place to protect network and information systems supporting your essential function(s) are effective and remain effective for the lifetime over which they are needed.</p> <p>You understand the assurance methods available to you and choose appropriate methods to gain confidence in the security of network and information systems supporting your essential function(s).</p> <p>Your confidence in the security as it relates to your technology, people, and processes can be justified to, and verified by, a third party.</p> <p>Security deficiencies uncovered by assurance activities are assessed, prioritised and remedied when necessary in a timely and effective way.</p> <p>The methods used for assurance are reviewed to ensure they are working as intended and remain the most appropriate method to use.</p> |

## Principle A3 Asset Management

*Everything required to deliver, maintain or support network and information systems necessary for the operation of essential functions is determined and understood. This includes data, people and systems, as well as any supporting infrastructure (such as power or cooling).*

### A3.a Asset Management

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| <p>Inventories of assets relevant to network and information systems supporting your essential function(s) are incomplete, non-existent or inadequately detailed.</p> <p>Only certain domains or types of asset are documented and understood.</p> <p>Dependencies between assets are not understood (such as the dependencies between IT and OT).</p> <p>Information assets, which could include personally identifiable information and / or important / critical data, are stored for long periods of time with no clear business need or retention policy.</p> <p>Knowledge critical to the management, operation, or recovery of network and information systems supporting your essential function(s) is held by one or two key individuals with no succession plan.</p> <p>Asset inventories are neglected and out of date.</p> | <p>All assets relevant to the secure operation of network and information systems supporting your essential function(s) are identified and inventoried (at a suitable level of detail). The inventory is kept up-to-date.</p> <p>Dependencies on supporting infrastructure (e.g. power, cooling etc) are recognised and recorded.</p> <p>You have prioritised your assets according to their importance to the operation of network and information systems supporting your essential function(s).</p> <p>You have assigned responsibility for managing all assets, including physical assets, relevant to the operation of network and information systems supporting your essential function(s).</p> <p>Assets relevant to network and information systems supporting your essential function(s) are managed with cyber security in mind throughout their lifecycle, from creation through to eventual decommissioning or disposal.</p> |

## Principle A4 Supply Chain

*The organisation understands and manages security risks to network and information systems supporting the operation of essential functions that arise as a result of dependencies on suppliers. This includes ensuring that appropriate measures are employed where third party services are used.*

### A4.a Supply Chain

*You understand and effectively manage the risks associated with suppliers to the security of network and information systems supporting the operation of your essential function(s).*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| <p>You do not know what data belonging to you is held by suppliers, or how it is managed.</p> <p>Elements of the supply chain for network and information systems supporting your essential function(s) are subcontracted and you have little or no visibility of the sub-contractors.</p> <p>You have no understanding of which contracts are relevant and / or relevant contracts do not specify appropriate security obligations.</p> <p>Suppliers have access to network and information systems that support your essential function(s) that is unrestricted, not monitored</p> | <p>You understand the general risks suppliers may pose to network and information systems supporting your essential function(s).</p> <p>You know the extent of your supply chain that supports network and information systems supporting your essential function(s), including sub-contractors.</p> <p>Suppliers to network and information systems that support your essential function(s) can demonstrate appropriate and proportionate levels of cyber security within the context of common threats.</p> <p>You understand which contracts are relevant and you include appropriate</p> | <p>You have a deep understanding of your supply chain, including sub-contractors, and the wider risks it faces.</p> <p>You consider factors such as your supplier's ownership, nationality, partnerships, competitors, other organisations with which they sub-contract and their approach to cyber security. These factors inform your risk assessment and are fully considered in your procurement lifecycle processes and purchasing decisions.</p> <p>Your approach to supply chain risk management considers the risks to network and information systems</p> |

|                                                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>or bypasses your own security controls.</p> | <p>security obligations, in relevant contracts.</p> <p>You are aware of all third-party connections and have assurance that they meet your organisation's security requirements.</p> <p>Your approach to security incident management considers incidents that might arise in your supply chain.</p> <p>You have confidence that information held by suppliers that is necessary for the operation of network and information systems supporting your essential function(s) is appropriately protected from common threats.</p> | <p>supporting your essential function(s) arising from supply chain subversion by capable and well-resourced threat actors.</p> <p>Critical suppliers to network and information systems supporting your essential functions(s) can demonstrate appropriate and proportionate levels of cyber security within the context of capable and well-resourced threat actors.</p> <p>You have confidence that information held by suppliers that is essential to the operation of network and information systems supporting your essential function(s) is appropriately protected from capable and well-resourced threat actors.</p> <p>You understand which contracts are relevant and you include appropriate security obligations, in relevant contracts.</p> <p>You have a proactive approach to contract management which may include a contract management plan for relevant contracts.</p> <p>Customer / supplier ownership of responsibilities is defined in contracts.</p> |
|------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

|  |  |                                                                                                                                                                                                                                                             |
|--|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  |  | <p>All network connections and data sharing with third parties are managed effectively and proportionately.</p> <p>When appropriate, your incident management process and that of your suppliers provide mutual support in the resolution of incidents.</p> |
|--|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

#### **A4.b Secure Software Development and Support**

*You actively maximise the use of secure and supported software, whether developed internally or sourced externally, within network and information systems supporting the operation of your essential function(s).*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                            | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                   | Achieved                                                                                                                                                                                                                                                                                                                                                                                                           |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                        | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                              |
| <p>Your software supplier(s) is unaware of the composition and provenance of software provided to you.</p> <p>Software, including updates and patches, undergoes little to no testing.</p> <p>Updates and patches often introduce new problems or fail to address existing issues.</p> <p>Vulnerabilities are discovered in software despite the negligible difficulty of implementing mitigations.</p> | <p>Your software supplier leverages secure development principles and practices.</p> <p>Your software supplier(s) can demonstrate a limited understanding of the composition and provenance of software provided to you.</p> <p>You consider the security of environments (e.g. development, test and production), including source code and repositories, used in the production of software to</p> | <p>Your software supplier(s) leverages an established secure software development framework (e.g. NIST Secure Software Development Framework (SSDF), Microsoft Secure Development Lifecycle (SDL)).</p> <p>Your software supplier can demonstrate a thorough understanding of the composition and provenance of software provided to you, including any third-party components used in the development of that</p> |

|  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|--|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <p>be appropriate and proportionate within the context of common threats.</p> <p>The testing regime uses a range of different approaches (e.g. static and dynamic analysis, unit and integration testing and point in time assessments) that verify all aspects of the development lifecycle covering both functional and non-functional testing.</p> <p>You have arrangements in place with your software supplier to receive timely security updates, patches and notifications.</p> <p>Software, including updates and patches, is obtained from your supplier(s) via secure channels.</p> <p>Your software supplier(s) has processes in place to identify, report and mitigate security vulnerabilities.</p> <p>You have arrangements in place with your software supplier to be notified of any significant events that may adversely impact network and information systems supporting your essential function(s).</p> <p>If open-source software is used, you have taken appropriate and proportionate steps to establish and maintain</p> | <p>software, and those components are being monitored for new vulnerabilities throughout the lifespan of the product.</p> <p>You consider the security of environments (e.g. development, test, and production), including source code and repositories, used in the production of software to be appropriate and proportionate within the context of capable and well-resourced threat actors.</p> <p>The software development lifecycle is informed by a detailed and up to date understanding of threat and applies appropriate techniques, such as threat modelling, to identify and assess potential vulnerabilities and attack vectors.</p> <p>You can attest to the authenticity and integrity of software, including updates and patches.</p> |
|--|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

|  |                                                                                                                                      |  |
|--|--------------------------------------------------------------------------------------------------------------------------------------|--|
|  | <p>sufficient confidence in its security for its use.</p> <p>You have appropriate support and maintenance arrangements in place.</p> |  |
|--|--------------------------------------------------------------------------------------------------------------------------------------|--|

## CAF – Objective B – Protecting against cyber attack

Proportionate security measures are in place to protect network and information systems supporting essential functions from cyber attack.

### Principle B1 Service Protection Policies, Processes and Procedures

*The organisation defines, implements, communicates and enforces appropriate policies, processes and procedures that direct its overall approach to securing systems and data that support operation of essential functions.*

#### **B1.a Policy, Process and Procedure Development**

*You have developed and continue to improve a set of cyber security and resilience policies, processes and procedures that manage and mitigate the risk of adverse impact to network and information systems supporting your essential function(s).*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                          | Partially Achieved                                                                                                                                                                                                                                                                                        | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                      | All the following statements are true                                                                                                                                                                                                                                                                     | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                         |
| <p>Your policies, processes and procedures are absent or incomplete.</p> <p>Policies, processes and procedures are not applied universally or consistently.</p> <p>People often or routinely circumvent policies, processes and procedures to achieve business objectives.</p> <p>Your organisation's security governance and risk management approach has no bearing on your policies, processes and procedures.</p> | <p>Your policies, processes and procedures document your overarching security governance and risk management approach, technical security practice and specific regulatory compliance.</p> <p>You review and update policies, processes and procedures in response to major cyber security incidents.</p> | <p>You fully document your overarching security governance and risk management approach, technical security practice and specific regulatory compliance.</p> <p>Cyber security is integrated and embedded throughout policies, processes and procedures and key performance indicators are reported to your executive management.</p> <p>Your organisation's policies, processes and procedures are developed to be practical, usable and</p> |

|                                                                                                                                                                                                                                                                                                                                                                                                                               |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>System security is totally reliant on users' careful and consistent application of manual security processes.</p> <p>Policies, processes and procedures have not been reviewed in response to major changes (e.g. technology or regulatory framework), or within a suitable period.</p> <p>Policies, processes and procedures are not readily available to staff, too detailed to remember, or too hard to understand.</p> | <p>appropriate to mitigate the risk of adverse impact to network and information systems supporting your essential function(s).</p> <p>Policies, processes and procedures that rely on user behaviour are practical, appropriate and achievable.</p> <p>You review and update policies, processes and procedures at suitably regular intervals to ensure they remain relevant. This is in addition to reviews following a major cyber security incident.</p> <p>Any changes to the essential function(s) or the threat it faces triggers a review of policies, processes and procedures.</p> <p>Your systems are designed so that they remain secure even when user security policies, processes and procedures are not always followed.</p> |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

**BI.b Policy, Process and Procedure Implementation**

*You have successfully implemented your security policies, processes and procedures and can demonstrate the security benefits achieved.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| <p>Policies, processes and procedures are ignored or only partially followed.</p> <p>How your policies, processes and procedures support the resilience of your essential function(s) is not well understood.</p> <p>Staff are unaware of their responsibilities under your policies, processes and procedures.</p> <p>You do not attempt to detect breaches of policies, processes and procedures.</p> <p>Policies, processes and procedures lack integration with other organisational policies, processes and procedures.</p> <p>Your policies, processes and procedures are not well communicated across your organisation.</p> | <p>Most of your policies, processes and procedures are followed and their application is monitored.</p> <p>Your policies, processes and procedures are integrated with other organisational policies, processes and procedures, including HR assessments of individuals' trustworthiness.</p> <p>All staff are aware of their responsibilities under your policies, processes and procedures.</p> <p>All breaches of policies, processes and procedures with the potential to adversely impact the essential function(s) are fully investigated. Other breaches are tracked, assessed for trends and action is taken to understand and address.</p> | <p>All your policies, processes and procedures are followed, their correct application and security effectiveness is evaluated.</p> <p>Your policies, processes and procedures are integrated with other organisational policies, processes and procedures, including HR assessments of individuals' trustworthiness.</p> <p>Your policies, processes and procedures are effectively and appropriately communicated across all levels of the organisation resulting in good staff awareness of their responsibilities.</p> <p>Appropriate action is taken to address all breaches of policies, processes and procedures with potential to adversely impact the essential function(s) including aggregated breaches.</p> |

## Principle B2 Identity and Access Control

*The organisation understands, documents and manages access to network and information systems supporting the operation of essential functions. Users (or automated functions) that can access data or systems are appropriately verified, authenticated and authorised.*

### **B2.a Identity Verification, Authentication and Authorisation**

*You robustly verify, authenticate and authorise access to network and information systems supporting your essential function(s).*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| <p>Initial identity verification is not robust enough to provide an acceptable level of confidence of a user's identity profile.</p> <p>Authorised users and systems with access to networks or information systems on which your essential function(s) depends cannot be individually identified.</p> <p>Unauthorised individuals or devices can access your network or information systems on which your essential function(s) depends.</p> <p>The number of authorised users and systems that have access to network and information systems is not limited to the minimum</p> | <p>Your process of initial identity verification is robust enough to provide a reasonable level of confidence of a user's identity profile before allowing an authorised user access to network and information systems that support your essential function(s).</p> <p>All authorised users and systems with access to network and information systems supporting your essential function(s) are individually identified and authenticated.</p> <p>The number of authorised users and systems that have access to network and information systems is limited to the minimum</p> | <p>Your process of initial identity verification is robust enough to provide a high level of confidence of a user's identity profile before allowing an authorised user access to network and information systems that support your essential function(s).</p> <p>Only authorised and individually authenticated users can physically access and logically connect to your network or information systems on which your essential function(s) depends.</p> <p>The number of authorised users and systems that have access to network and information systems is limited to the minimum</p> |

|                                                                                                                                                                     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>necessary to support your essential function(s).</p> <p>Your approach to authenticating users, devices and systems does not follow up to date best practice.</p> | <p>necessary to support your essential function(s).</p> <p>You use additional strong authentication mechanisms, such as multi-factor authentication (MFA), for privileged access to all network and information systems that operate or support your essential function(s).</p> <p>You individually authenticate and authorise all remote access to all network and information systems that support your essential function(s).</p> <p>The list of users and systems with access to network and information systems supporting and delivering the essential function(s) is reviewed on a regular basis, at least annually.</p> <p>Your approach to authenticating users, devices and systems follows up to date best practice.</p> | <p>necessary to support your essential function(s).</p> <p>You use additional strong authentication mechanisms, such as multi-factor authentication (MFA), for all user access, including remote access, to all network and information systems that operate or support your essential function(s).</p> <p>The list of users and systems with access to network and information systems supporting and delivering the essential function(s) is reviewed on a regular basis, at least every six months.</p> <p>Your approach to authenticating users, devices and systems follows up to date best practice.</p> |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## B2.b Device Management

*You fully know and have trust in the devices that are used to access your networks, information systems and data that support your essential function(s).*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| <p>Users can connect to network and information systems supporting your essential function(s) using devices that are not corporately owned and managed.</p> <p>Privileged users can perform privileged operations from devices that are not corporately owned and managed.</p> <p>You have not gained assurance in the security of any third-party devices or networks connected to your systems.</p> <p>Physically connecting a device to network and information systems gives that device access without device or user authentication.</p> | <p>Only corporately owned and managed devices can access your essential function(s) network and information systems.</p> <p>All privileged operations are performed from corporately owned and managed devices. These devices provide sufficient separation, using a risk-based approach, from the activities of standard users.</p> <p>You have sought to understand the security properties of third-party devices and networks before they can be connected to your systems. You have taken appropriate steps to mitigate any risks identified.</p> <p>The act of connecting to a network port or cable does not grant access to any systems.</p> <p>You are able to detect unknown devices being connected to network and information systems and investigate such incidents.</p> | <p>All privileged operations performed on network and information systems supporting your essential function(s) are conducted from highly trusted devices, such as Privileged Access Workstations, dedicated solely to those operations.</p> <p>You either obtain independent and professional assurance of the security of third-party devices or networks before they connect to network and information systems, or you only allow third-party devices or networks that are dedicated to supporting network and information systems to connect.</p> <p>You perform certificate-based device identity management and only allow known devices to access systems necessary for the operation of your essential function(s).</p> <p>You perform regular scans to detect unknown devices and investigate any findings.</p> |

## B2.c Privileged User Management

*You closely manage privileged user access to network and information systems supporting your essential function(s).*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| <p>The identities of the individuals with privileged access to network and information systems (infrastructure, platforms, software, configuration etc) supporting your essential function(s) are not known or not managed.</p> <p>Privileged user access to network and information systems supporting your essential function(s) is via weak authentication mechanisms (e.g. only simple passwords).</p> <p>The list of privileged users has not been reviewed recently (e.g. within the last 12 months).</p> <p>Privileged user access is granted on a system-wide basis rather than by role or function(s).</p> <p>Privileged user access to network and information systems supporting your essential function(s) is via generic, shared or default name accounts.</p> | <p>All privileged user access to network and information systems supporting your essential function(s) requires strong authentication, such as multi-factor authentication (MFA).</p> <p>The identities of the individuals with privileged access to network and information systems (infrastructure, platforms, software, configuration etc) supporting your essential function(s) are known and managed. This includes third parties.</p> <p>Activity by privileged users is routinely reviewed and validated (e.g. at least annually).</p> <p>Privileged users are only granted specific privileged user access rights which are essential to their business role or function.</p> | <p>Privileged user access to network and information systems supporting your essential function(s) is carried out from dedicated separate accounts that are closely monitored and managed.</p> <p>The issuing of temporary, time-bound rights for privileged user access and / or external third-party support access is in place.</p> <p>Privileged user access rights are regularly reviewed and always updated as part of your joiners, movers and leavers process.</p> <p>All privileged user activity is routinely reviewed, validated and recorded for offline analysis and investigation.</p> |

|                                                                                                                                                                                                                                                                                                                                                                                                        |  |  |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|--|
| <p>Where there are “always on” terminals which can perform privileged actions (such as in a control room), there are no additional controls (e.g. physical controls) to ensure access is appropriately restricted.</p> <p>There is no logical separation between roles that an individual may have and hence the actions they perform (e.g. access to corporate email and privilege user actions).</p> |  |  |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|--|

## B2.d Identity and Access Management (IdAM)

*You closely manage and maintain identity and access control for users, devices and systems accessing network and information systems supporting your essential function(s).*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                    | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                    | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| <p>Greater access rights are granted than necessary.</p> <p>Identity validation and requirement for access of a user, device or systems is not carried out.</p> <p>User access rights are not reviewed when users change roles.</p> <p>User access rights remain active when users leave your organisation.</p> <p>Access rights granted to devices or systems to access other devices and systems are not reviewed on a regular basis (at least annually).</p> | <p>You follow a robust procedure to verify each user and issue the minimum required access rights.</p> <p>You regularly review access rights and those no longer needed are revoked.</p> <p>User access rights are reviewed when users change roles via your joiners, leavers and movers process.</p> <p>All user, device and system access to the systems supporting the essential function(s) is logged and monitored, but it is not compared to other log data or access records.</p> | <p>You follow a robust procedure to verify each user and issue the minimum required access rights, and the application of the procedure is regularly audited.</p> <p>User access rights are reviewed both when people change roles via your joiners, leavers and movers process and at regular intervals – at least annually.</p> <p>All user, device and systems access to network and information systems supporting your essential function(s) is logged and monitored.</p> <p>You regularly review access logs and correlate this data with other access records and expected activity.</p> <p>Attempts by unauthorised users, devices or systems to connect to network and information systems supporting your essential function(s) are alerted, promptly assessed and investigated.</p> |

## Principle B3 Data Security

*Data stored or transmitted electronically is protected from actions such as unauthorised access, modification, or deletion that may cause an adverse impact on essential functions. Such protection extends to the means by which authorised users, devices and systems access critical data necessary for the operation of essential functions. It also covers information that would assist a threat actor, such as design details of network and information systems.*

### **B3.a Understanding Data**

*You have a good understanding of data important to the operation of network and information systems supporting your essential function(s), where it is stored, where it travels and how unavailability or unauthorised access, uncontrolled release, modification or deletion would adversely impact the essential function(s). This also applies to third parties storing or accessing data important to the operation of your essential function(s).*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                             | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                         | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                  | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| <p>You have incomplete knowledge of what data is used by and produced in the operation of network and information systems supporting your essential function(s).</p> <p>You have not identified the important data on which network and information systems supporting your essential function(s) relies.</p> <p>You have not identified who has access to data important to the operation of network and information systems supporting your essential function(s).</p> | <p>You have identified and catalogued all the data important to the operation of network and information systems supporting your essential function(s), or that would assist a threat actor.</p> <p>You have identified and catalogued who has access to the data important to the operation of network and information systems supporting your essential function(s).</p> <p>You regularly review location, transmission, quantity and quality of data important to the operation</p> | <p>You have identified and catalogued all the data important to the operation of network and information systems supporting your essential function(s), or that would assist a threat actor.</p> <p>You have identified and catalogued who has access to the data important to the operation of network and information systems supporting your essential function(s).</p> <p>You maintain a current understanding of the location, quantity and quality of data important to the</p> |

|                                                                                                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>You have not clearly articulated the impact of data compromise or lack of availability.</p> | <p>of network and information systems supporting your essential function(s).</p> <p>You have identified all mobile devices and media that hold data important to the operation of network and information systems supporting your essential function(s).</p> <p>You understand and document the impact on your essential function(s) of all relevant scenarios, including unauthorised data access, uncontrolled release, modification or deletion, or when authorised users are unable to appropriately access this data.</p> <p>You occasionally validate these documented impact statements.</p> | <p>operation of network and information systems supporting your essential function(s).</p> <p>You take steps to remove or minimise unnecessary copies or unneeded historic data.</p> <p>You have identified all mobile devices and media that may hold data important to the operation of network and information systems supporting your essential function(s).</p> <p>You maintain a current understanding of the data links used to transmit data that is important to network and information systems supporting your essential function(s).</p> <p>You understand the context, limitations and dependencies of your important data.</p> <p>You understand and document the impact on your essential function(s) of all relevant scenarios, including unauthorised data access, uncontrolled release, modification or deletion, or when authorised users are unable to appropriately access this data.</p> <p>You validate these documented impact statements regularly, at least annually.</p> |
|------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

**B3.b Data in Transit**

*You have protected the transit of data important to the operation of network and information systems supporting your essential function(s). This includes the transfer of data to third parties.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                    | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                         | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                      | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| <p>You do not know what all your data links are, or which carry data important to the operation of the essential function(s).</p> <p>Data important to the operation of the essential function(s) travels without technical protection over non-trusted or openly accessible carriers.</p> <p>Critical data paths that could fail, be jammed, be overloaded, etc. have no alternative path.</p> | <p>You have identified and protected (effectively and proportionately) all the data links that carry data important to the operation of your essential function(s).</p> <p>You apply appropriate physical and / or technical means (e.g. cryptography) to protect data that travels over non-trusted or openly accessible carriers, but you have limited or no confidence in the robustness of the protection applied.</p> | <p>You have identified and protected (effectively and proportionately) all the data links that carry data important to the operation of your essential function(s).</p> <p>You apply appropriate physical and / or technical means (e.g. cryptography) to protect data that travels over non-trusted or openly accessible carriers, with justified confidence in the robustness of the protection applied.</p> <p>Suitable alternative transmission paths are available where there is a significant risk of impact on the operation of the essential function(s) due to resource limitation (e.g. transmission equipment or function failure, or important data being blocked or jammed).</p> |

**B3.c Stored Data**

*You have protected stored soft and hard copy data important to the operation of network and information systems supporting your essential function(s).*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                     | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| <p>You have no, or limited, knowledge of where data important to the operation of network and information systems supporting your essential function(s) is stored.</p> <p>You have not protected vulnerable stored data important to the operation of network and information systems supporting your essential function(s) in a suitable way.</p> <p>Backups are incomplete, untested, not adequately secured or could be inaccessible in a disaster recovery or business continuity situation.</p> | <p>All copies of data important to the operation of network and information systems supporting your essential function(s) are necessary. Where this important data is transferred to less secure systems, the data is provided with limited detail and / or as a read-only copy.</p> <p>You have applied suitable physical and / or technical means to protect this important stored data from unauthorised access, modification or deletion.</p> <p>If cryptographic protections are used you apply suitable technical and procedural means, but you have limited or no confidence in the robustness of the protection applied.</p> <p>You have suitable, secured backups of data to allow the operation of network and information systems supporting your essential function(s) to continue</p> | <p>All copies of data important to the operation of network and information systems supporting your essential function(s) are necessary. Where this important data is transferred to less secure systems, the data is provided with limited detail and / or as a read-only copy.</p> <p>You have applied suitable physical and / or technical means to protect this important stored data from unauthorised access, modification or deletion.</p> <p>If cryptographic protections are used you apply suitable technical and procedural means, and you have justified confidence in the robustness of the protection applied.</p> <p>You have suitable, secured backups of data to allow the operation of network and information systems supporting your essential function(s) to continue</p> |

|  |                                                                                                                                                           |                                                                                                                                                                                                                                     |
|--|-----------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <p>should the original data not be available. This may include off-line or segregated backups, or appropriate alternative forms such as paper copies.</p> | <p>should the original data not be available. This may include off-line or segregated backups, or appropriate alternative forms such as paper copies.</p> <p>Necessary historic or archive data is suitably secured in storage.</p> |
|--|-----------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

**B3.d Mobile Data**

*You have protected data important to the operation of network and information systems supporting your essential function(s) on mobile devices (e.g. smartphones, tablets and laptops).*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                              | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                      | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                          | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                   | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| <p>You do not know which mobile devices may hold data important to the operation of network and information systems supporting your essential function(s).</p> <p>You allow data important to the operation of network and information systems supporting your essential function(s) to be stored on devices not managed by your organisation, or to at least equivalent standard.</p> <p>Data on mobile devices is not technically secured, or only some is secured.</p> | <p>You know which mobile devices hold data important to the operation of network and information systems supporting your essential function(s).</p> <p>Data important to the operation of network and information systems supporting your essential function(s) is stored on mobile devices only when they have at least the security standard aligned to your overarching security policies.</p> <p>Data on mobile devices is technically secured.</p> | <p>Mobile devices that hold data that is important to the operation of network and information systems supporting your essential function(s) are catalogued, are under your organisation's control and configured according to best practice for the platform, with appropriate technical and procedural policies in place.</p> <p>Your organisation can remotely wipe all mobile devices holding data important to the operation of network and information systems supporting your essential function(s).</p> <p>You have minimised this data on these mobile devices. Some data may be automatically deleted off mobile devices after a certain period.</p> |

**B3.e Media / Equipment Sanitisation**

*Before reuse and / or disposal you appropriately sanitise devices, equipment and removable media holding data important to the operation of network and information systems supporting your essential function(s).*

| Not Achieved                                                                                                                                                                                                                      | Partially Achieved                                                                                                                                                                                   | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                  | All the following statements are true                                                                                                                                                                | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Some or all devices, equipment or removable media that hold data important to the operation of network and information systems supporting your essential function(s) are reused or disposed of without sanitisation of that data. | Data important to the operations of network and information systems supporting your essential function(s) is removed from all devices, equipment and removable media before reuse and / or disposal. | <p>You catalogue and track all devices that contain data important to the operation of network and information systems supporting your essential function(s) (whether a specific storage device or one with integral storage).</p> <p>Data important to the operation of network and information systems supporting your essential function(s) is removed from all devices, equipment and removable media before reuse and / or disposal using an assured product or service.</p> |

## Principle B4 System Security

*Network and information systems and technology critical for the operation of essential functions are protected from cyber attack. An organisational understanding of risk to essential functions informs the use of robust and reliable protective security measures to effectively limit opportunities for threat actors to compromise networks and systems.*

### **B4.a Secure by Design**

*You design security into network and information systems that support the operation of your essential function(s). You minimise their attack surface and ensure that the operation of your essential function(s) should not be impacted by the exploitation of any single vulnerability.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| <p>Network and information systems supporting the operation of the essential function(s) are not appropriately segregated from other systems.</p> <p>Internet services, such as browsing and email are accessible from network and information systems supporting your essential function(s).</p> <p>Data flows between network and information systems supporting your essential function(s) and other systems are complex, making it hard to discriminate between legitimate and illegitimate / malicious traffic.</p> | <p>You employ appropriate expertise to design network and information systems supporting your essential function(s).</p> <p>You design strong boundary defences where network and information systems interface with other organisations or the world at large.</p> <p>You design simple data flows between network and information systems and any external interface to enable effective monitoring.</p> <p>You design to make network and information system recovery simple.</p> <p>All inputs to network and information systems</p> | <p>You employ appropriate expertise to design network and information systems supporting your essential function(s).</p> <p>Network and information systems are segregated into appropriate security zones (e.g. systems supporting the essential function(s) are segregated in a highly trusted, more secure zone).</p> <p>The network and information systems supporting your essential function(s) are designed to have simple data flows between components to support effective security monitoring.</p> |

|                                                                                                                                                                     |                                                                                                                                                                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Remote or third-party accesses circumvent some network controls to gain more direct access to network and information systems supporting the essential function(s). | supporting your essential function(s) are checked and validated at the network boundary where possible, or additional monitoring is in place for content-based attacks. | <p>The network and information systems supporting your essential function(s) are designed to be easy to recover.</p> <p>Content-based attacks are mitigated for all inputs to network and information systems that affect the essential function(s) (e.g. via transformation and inspection / sanitisation and validation).</p> <p>If automated decision-making technologies are in use, you design and apply appropriate restrictions to prevent actions that could have an adverse impact on network and information systems supporting your essential function(s).</p> |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## B4.b Secure Configuration

*You securely configure network and information systems that support the operation of your essential function(s).*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| <p>You have not identified the assets that need to be carefully configured to maintain the security of network and information systems supporting your essential function(s).</p> <p>Policies relating to the security of operating system builds or configuration are not applied consistently across network and information systems relating to your essential function(s).</p> <p>Configuration details are not recorded or lack enough information to be able to rebuild the system or device.</p> <p>The recording of security changes or adjustments that affect your essential function(s) is lacking or inconsistent.</p> <p>Generic, shared, default name and built-in accounts have not been removed or disabled.</p> | <p>You have identified and documented the assets that need to be carefully configured to maintain the security of network and information systems supporting your essential function(s).</p> <p>Secure platform and device builds are used across the estate.</p> <p>Consistent, secure and minimal system and device configurations are applied across the same types of environment.</p> <p>Changes and adjustments to security configurations at security boundaries of network and information systems supporting your essential function(s) are approved and documented.</p> <p>You verify software before installation is permitted.</p> <p>Generic, shared, default name and built-in accounts have been removed or disabled. Where this is not possible, credentials to</p> | <p>You have identified, documented and actively manage (e.g. maintain security configurations, patching, updating according to good practice) the assets that need to be carefully configured to maintain the security of network and information systems supporting your essential function(s).</p> <p>All platforms conform to your secure, defined baseline build, or the latest known good configuration version for that environment.</p> <p>You closely and effectively manage changes in your environment, ensuring that network and information systems configurations are secure and documented.</p> <p>You regularly review and validate that network and information systems have the expected, secure settings and configuration.</p> |

|                                                                                                                                                                      |                                                                                                                                                                                                                                                                 |                                                                                                                                                                                                                                                                                                                                                                                                         |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>Standard users are able to change settings that would adversely impact the security of network and information systems supporting your essential function(s).</p> | <p>these accounts have been changed. Service accounts are appropriately protected.</p> <p>Standard users are not able to change settings that would adversely impact the security of network and information systems supporting your essential function(s).</p> | <p>Only permitted software can be installed.</p> <p>If automated decision-making technologies are in use, their operation is well understood, and decisions can be replicated.</p> <p>Generic, shared, default name and built-in accounts have been removed or disabled. Where this is not possible, credentials to these accounts have been changed. Service accounts are appropriately protected.</p> |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

### B4.c Secure Management

*You manage your organisation's network and information systems that support the operation of your essential function(s) to enable and maintain security.*

| Not Achieved                                                                                                                                                                                                                                                                     | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                 | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| <p>Your systems and devices supporting the operation of the essential function(s) are administered or maintained from devices that are not corporately owned and managed.</p> <p>You do not have good or current technical documentation of network and information systems.</p> | <p>Your systems and devices supporting the operation of the essential function(s) are only administered or maintained by authorised privileged users from devices sufficiently separated, using a risk-based approach, from the activities of standard users.</p> <p>Technical knowledge about network and information systems, such as documentation and network diagrams, is regularly reviewed and updated.</p> <p>You prevent, detect and remove malware, and unauthorised software. You use technical, procedural and physical measures as necessary.</p> | <p>Your systems and devices supporting the operation of the essential function(s) are only administered or maintained by authorised privileged users from highly trusted devices, such as Privileged Access Workstations, dedicated solely to those operations.</p> <p>You regularly review and update technical knowledge about network and information systems, such as documentation and network diagrams, and ensure they are securely stored.</p> <p>You prevent, detect and remove malware, and unauthorised software. You use technical, procedural and physical measures as necessary.</p> |

#### B4.d. Vulnerability Management

*You manage known vulnerabilities in network and information systems to prevent adverse impact on your essential function(s).*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | All the following statements below are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| <p>You do not understand the exposure of network and information systems supporting your essential function(s) to publicly-known vulnerabilities.</p> <p>You do not mitigate externally exposed vulnerabilities promptly.</p> <p>You have not recently tested to verify your understanding of the vulnerabilities of network and information systems that support your essential function(s).</p> <p>You have not suitably mitigated systems or software that is no longer supported.</p> <p>You are not pursuing replacement for unsupported systems or software.</p> | <p>You maintain a current understanding of the exposure of network and information systems supporting your essential function(s) to publicly-known vulnerabilities.</p> <p>Announced vulnerabilities for all software packages used in network and information systems supporting your essential function(s) are tracked, prioritised and externally exposed vulnerabilities are mitigated (e.g. by patching) promptly.</p> <p>Some vulnerabilities that are not externally exposed have temporary mitigations for an extended period.</p> <p>You have temporary mitigations for unsupported systems and software while pursuing migration to supported technology.</p> <p>You regularly test to fully understand the vulnerabilities of network and information systems that support the operation of your essential function(s).</p> | <p>You maintain a current understanding of the exposure of network and information systems supporting your essential function(s) to publicly-known vulnerabilities.</p> <p>Announced vulnerabilities for all software packages used in network and information systems supporting your essential function(s) are tracked, prioritised and mitigated (e.g. by patching) promptly.</p> <p>You regularly test to fully understand the vulnerabilities of network and information systems that support the operation of your essential function(s) and verify this understanding with third-party testing.</p> <p>You actively maximise the use of supported software, firmware and hardware in network and information systems supporting your essential function(s).</p> |

## Principle B5 Resilient Networks and Systems

*The organisation builds resilience against cyber attack and system failure into the design, implementation, operation and management of systems that support the operation of your essential function(s).*

### **B5.a Resilience Preparation**

*You are prepared to restore the operation of your essential function(s) following adverse impact to network and information systems.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | Partially Achieved                                                                                                                                                                                                                                                                                                                                   | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Any of the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | All the following statements are true                                                                                                                                                                                                                                                                                                                | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| <p>You have limited understanding of all the elements that are required to restore operation of network and information systems supporting your essential function(s).</p> <p>You have not completed business continuity and disaster recovery plans for network and information systems, including their dependencies, supporting the operation of the essential function(s).</p> <p>You have not fully assessed the practical implementation of your business continuity and disaster recovery plans.</p> | <p>You know all network and information systems, and underlying technologies, that are necessary to restore the operation of your essential function(s) and understand their interdependence.</p> <p>You know the order in which systems need to be recovered to efficiently and effectively restore the operation of the essential function(s).</p> | <p>You have business continuity and disaster recovery plans that have been tested for practicality, effectiveness and completeness. Appropriate use is made of different test methods (e.g. manual fail-over, table-top exercises, or red-teaming).</p> <p>You use your security awareness and threat intelligence sources to identify new or heightened levels of risk, which result in immediate and potentially temporary security measures to enhance the security of network and information systems supporting your essential function(s), (e.g. in response to a widespread outbreak of very damaging malware).</p> |

### B5.b Design for Resilience

*You design network and information systems supporting your essential function(s) to be resilient to cyber security incidents. Systems are appropriately segregated and resource limitations are mitigated.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                             | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                         | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| <p>Network and information systems supporting the operation of your essential function(s) are not appropriately segregated.</p> <p>Internet services, such as browsing and email, are accessible from network and information systems supporting your essential function(s).</p> <p>You do not understand or lack plans to mitigate all resource limitations that could adversely affect your essential function(s).</p> | <p>Network and information systems supporting the operation of your essential function(s) are logically separated from your business systems (e.g. they reside on the same network as the rest of the organisation but within a DMZ).</p> <p>Internet services, such as browsing and email, are not accessible from network and information systems supporting your essential function(s).</p> <p>Resource limitations (e.g. network bandwidth, single network paths) have been identified but not fully mitigated.</p> | <p>Network and information systems supporting the operation of your essential function(s) are segregated from other business and external systems by appropriate technical and physical means (e.g. separate network and system infrastructure with independent user administration).</p> <p>Internet services, such as browsing and email, are not accessible from network and information systems supporting your essential function(s).</p> <p>You have identified and mitigated all resource limitations (e.g. bandwidth limitations and single network paths).</p> <p>You have identified and mitigated any geographical constraints or weaknesses. (e.g. systems that your essential function(s) depends upon are replicated in another</p> |

|  |  |                                                                                                                                                                                                                                        |
|--|--|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  |  | <p>location, important network connectivity has alternative physical paths and service providers).</p> <p>You review and update assessments of dependencies, resource and geographical limitations and mitigations when necessary.</p> |
|--|--|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

### **B5.c Backups**

*You hold accessible and secured current backups of data and information needed to recover operation of your essential function(s) following an adverse impact to network and information systems.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                        | Partially Achieved                                                                                                                                                                                                                                                                                                                                            | Achieved                                                                                                                                                                                                                                                                                                                        |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                    | All the following statements are true                                                                                                                                                                                                                                                                                                                         | All the following statements are true                                                                                                                                                                                                                                                                                           |
| <p>Backup coverage is incomplete and does not include all relevant data and information needed to restore the operation of your essential function(s).</p> <p>Backups are not frequent enough for the operation of your essential function(s) to be restored effectively.</p> <p>Your restoration process does not restore your essential function(s) in a suitable time frame.</p> | <p>You have appropriately secured backups (including data, configuration information, software, equipment, processes and knowledge). These backups will be accessible to recover from an extreme event including ransomware attack.</p> <p>You routinely test backups to ensure that the backup process function(s) correctly and the backups are usable.</p> | <p>Your comprehensive, automatic and tested technical and procedural backups are secured at centrally accessible or secondary sites to recover from an extreme event.</p> <p>Backups of all important data and information needed to recover the essential function(s) are made, tested, documented and routinely reviewed.</p> |

## Principle B6 Staff Awareness and Training

*Staff have appropriate awareness, knowledge and skills to carry out their organisational roles effectively in relation to the security of network and information systems supporting the operation of your essential function(s).*

### **B6.a Cyber Security Culture**

*You develop and maintain a positive cyber security culture and a shared sense of responsibility.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| <p>People in your organisation do not understand what they contribute to the cyber security of network and information systems supporting your essential function(s).</p> <p>People in your organisation do not know how to raise a concern about cyber security.</p> <p>People believe that reporting issues may get them into trouble.</p> <p>Your organisation's approach to cyber security is perceived by staff as hindering the business of the organisation and may encourage poor security behaviours.</p> <p>Formal or informal incentives and rewards conflict with the promotion</p> | <p>Your executive management understand and widely communicate the importance of a positive cyber security culture. Positive attitudes, behaviours and expectations are described for your organisation.</p> <p>All people in your organisation understand the contribution they make to the cyber security of network and information systems supporting your essential functions(s).</p> <p>All individuals in your organisation know who to contact and where to access more information about cyber security. They know how to raise a cyber security issue.</p> <p>You identify and address issues that inhibit people</p> | <p>Your executive management clearly and effectively communicates the organisation's cyber security priorities and objectives to all staff. Your organisation displays positive cyber security attitudes, behaviours, expectations.</p> <p>People in your organisation raising potential cyber security incidents and issues are treated positively.</p> <p>Individuals at all levels in your organisation routinely report concerns or issues about cyber security and are recognised for their contribution to keeping the organisation secure.</p> <p>Your management is seen to be committed to and</p> |

|                                |                                                                                |                                                                                                                                                                                                                                                                                                                                      |
|--------------------------------|--------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| of positive security outcomes. | from behaving in a manner that supports your intended cyber security outcomes. | <p>actively involved in cyber security.</p> <p>Your organisation communicates openly about cyber security, with any concern being taken seriously.</p> <p>People across your organisation collaborate in cyber security activities and improvements, building joint ownership and bringing knowledge of their area of expertise.</p> |
|--------------------------------|--------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

### **B6.b Cyber Security Training**

*The people who support the operation of network and information systems supporting your essential function(s) are appropriately trained in cyber security.*

| Not Achieved                                                                                                                                                                                                                                                                                  | Partially Achieved                                                                                                                                                                                                                                                                                                     | Achieved                                                                                                                                                                                                                                                                                                                                         |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                              | All the following statements are true                                                                                                                                                                                                                                                                                  | All the following statements are true                                                                                                                                                                                                                                                                                                            |
| <p>There are teams who operate and support your essential function(s) that lack any cyber security training.</p> <p>Cyber security training is restricted to specific roles in your organisation.</p> <p>Cyber security training records for your organisation are lacking or incomplete.</p> | <p>You have defined appropriate cyber security training and awareness activities for all roles in your organisation, from executives to the most junior roles.</p> <p>You use a range of teaching and communication techniques for cyber security training and awareness to reach the widest audience effectively.</p> | <p>All people in your organisation, from the most senior to the most junior, follow appropriate cyber security training paths.</p> <p>Each individual's cyber security training is tracked and refreshed at suitable intervals.</p> <p>You routinely evaluate your cyber security training and awareness activities to ensure they reach the</p> |

|                                                                                                                                                                                                                                                                                                                                                                                                        |                                                        |                                                                                                                                                                                                                      |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>Training is used as a “silver bullet” for all user security behaviours.</p> <p>The success of training is only measured by the number of people reached, rather than assessing whether it has a positive impact on security behaviours.</p> <p>Training materials contain out of date or contradictory information, or information that conflicts with other policies, processes or procedures.</p> | <p>Cyber security information is easily available.</p> | <p>widest audience and are effective.</p> <p>You make cyber security information and good practice guidance easily accessible, widely available and you know it is referenced and used within your organisation.</p> |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## CAF – Objective C – Detecting Cyber Security Events

Capabilities exist to ensure security defences remain effective and to detect cyber security events and incidents adversely affecting, or with the potential to adversely affect, essential function(s).

### Principle C1 Security Monitoring

*The organisation monitors the security status of network and information systems supporting the operation of essential function(s) in order to detect security events indicative of a security incident.*

#### **C1.a Sources and Tools for Logging and Monitoring**

*The data sources and tools that you include in your logging and monitoring allow for timely identification of events which might adversely affect the security or resiliency of network and information system(s) supporting the operation of your essential function(s).*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                               | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                     | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                      |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                           | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                  | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                         |
| <p>Data relating to the security and operation of network and information systems supporting your essential function(s) is not collected.</p> <p>You are not able to audit the activities of users and systems in relation to network and information systems supporting your essential function(s).</p> <p>You do not monitor traffic crossing your network boundary.</p> <p>Log data cannot be synchronised using an</p> | <p>Data relating to the security and operation of some areas of network and information systems supporting your essential function(s) is collected but coverage is not comprehensive.</p> <p>Some user and system monitoring is done, but not covering a fully agreed list of suspicious or undesirable behaviour.</p> <p>You monitor traffic crossing your network boundary (including IP address</p> | <p>Monitoring is based on a thorough understanding of network and information systems supporting your essential function(s), techniques used by threat actors, and awareness of what logging and monitoring is required to detect events and incidents that could affect the operation of your essential function(s).</p> <p>Your monitoring data provides enough detail to promptly and reliably detect security events,</p> |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |                                                                                                                                                                                                                                                                                                                                                                                        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>accurate common time source.</p> <p>Logs are stored in locations where they are not readily available to authorised users and systems.</p> <p>Your monitoring tools cannot be configured to make use of new log streams as they come online.</p> <p>Your monitoring tools are only able to make use of a fraction of the log data being collected.</p> <p>You do not understand where log data is stored or how long it should be stored for.</p> <p>You have no way of ensuring log data is being captured as expected and available when needed.</p> | <p>connections as a minimum).</p> <p>Some but not all log datasets can be easily queried with search tools to aid in investigations.</p> <p>Your monitoring tools work with most log data, with some configuration.</p> <p>Your monitoring tools can make use of log data that would capture all common threats.</p> <p>You ensure log data is available for analysis when needed.</p> | <p>incidents and support investigations. This is reviewed regularly and after a significant security event.</p> <p>Extensive monitoring of user and system activity in relation to network and information systems that support your essential function(s) enables you to promptly detect policy violations, suspicious or undesirable user and system behaviour, deviations from normal / routine behaviour or abnormalities indicative of adverse activity.</p> <p>Your logging and monitoring capability includes host-based and network monitoring.</p> <p>All new network and information systems supporting your essential function(s) are considered as potential logging and monitoring data sources to maintain a comprehensive monitoring capability.</p> <p>Log datasets are synchronised including using an accurate common time source so that separate datasets can be correlated in appropriate ways.</p> <p>You enrich log data with other network and information systems data to</p> |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

|  |  |                                                                                                                                                                                                                                                                                        |
|--|--|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  |  | <p>provide a more comprehensive picture of actions and behaviours.</p> <p>Your monitoring tools make use of log data to pinpoint activity.</p> <p>You regularly review the data sources and tools included in your logging and monitoring strategy to ensure it remains effective.</p> |
|--|--|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

### C1.b Securing Logs

*You hold log data securely and grant appropriate user and system access only to accounts with a business need. Log data is held for a suitable retention period, after which it is deleted.*

| Not Achieved                                                                                                                                                                                                                                                                                                     | Partially Achieved                                                                                                                                                                                                                                                                                                                       | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                 | All the following statements are true                                                                                                                                                                                                                                                                                                    | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                        |
| <p>It is possible for log data to be easily edited or deleted by unauthorised users / systems or attackers.</p> <p>There is no control of the users and systems that can access log data.</p> <p>There is no monitoring of the access to log data.</p> <p>There are no policies covering access to log data.</p> | <p>Only authorised users and systems can access log data.</p> <p>There is some monitoring of access to log data (e.g. copying, deleting or modification, or even viewing).</p> <p>You have defined and implemented retention periods for log data.</p> <p>You have given legitimate reasons for accessing log data in your policies.</p> | <p>Appropriate access to log data is limited to those users and systems with a business need.</p> <p>The logging architecture has mechanisms, policies, processes and procedures to ensure that it can protect itself from threats comparable to those that it is trying to identify. This includes protecting the function itself and the data within it.</p> <p>Log data analysis and normalisation is only performed on copies of the</p> |

|  |  |                                                                                                                                                                                                                                                                                                                               |
|--|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  |  | <p>log data keeping the master copy unaltered.</p> <p>All actions involving log data (e.g. copying, deleting, modification, or even viewing) can be traced back to a unique user or system.</p> <p>The integrity of log data is protected, verified and any modification, including deletion, is detected and attributed.</p> |
|--|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

### **C1.c Generating Alerts**

*Evidence of potential security incidents contained in your monitoring data is reliably identified and where appropriate triggers alerts.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                         | Partially Achieved                                                                                                                                                                                                                                                                                                                                                      | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                     | All the following statements are true                                                                                                                                                                                                                                                                                                                                   | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                    |
| <p>You do not apply updates to your detection security technologies in a timely way, after receiving them (e.g. AV signature updates, other threat signatures or Indicators of Compromise (IoCs)).</p> <p>Security alerts relating to network and information systems supporting your essential function(s) are not prioritised.</p> <p>The enrichment of security alerts within network and information systems</p> | <p>You easily detect the presence of Indicators of Compromise (IoCs) on network and information systems supporting your essential function(s), such as known malicious command and control signatures.</p> <p>You apply some updates, new signatures and IoCs in a timely way.</p> <p>Security alerts relating to network and information systems that support your</p> | <p>You easily detect the presence of Indicators of Compromise (IoCs) on network and information systems supporting your essential function(s), such as known malicious command and control signatures, as well as abnormalities or behaviours indicative of adverse activity.</p> <p>You apply all updates, new signatures and IoCs promptly.</p> <p>Security alerts relating to all network and information systems supporting your</p> |

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>supporting your essential function(s) cannot be performed.</p> <p>You do not confidently detect the presence of IoCs on network and information systems supporting your essential function(s), such as known malicious command and control signatures (e.g. because applying the indicator is difficult or your log data is not sufficiently detailed).</p> <p>You do not monitor for user or system abnormalities indicative of adverse activity.</p> <p>Logs are monitored infrequently.</p> | <p>essential function(s) are prioritised.</p> <p>The enrichment of alerts within network and information systems supporting your essential function(s) is performed but not as part of the original alert.</p> <p>Detections and alerting rely on off the shelf tooling without customisation or users reporting events and potential incidents.</p> <p>There is a documented and shared process for all users who support the operation of the essential function to report events and potential security incidents.</p> <p>Where appropriate, detections and alerting result in automated actions being taken. (e.g. malware identified by AV is quarantined).</p> <p>You monitor on an irregular basis for user or system abnormalities indicative of adverse activity.</p> <p>Logs are monitored at regular intervals.</p> | <p>essential function(s) are prioritised and this information is used to support incident management.</p> <p>Alerts are routinely enriched within network and information systems supporting your essential function(s). The enrichment of these alerts is performed in almost real time and as part of the original alert.</p> <p>Alerts and the underlying detections are regularly reviewed and tested to ensure they are generated promptly and reliably, and it is possible to distinguish genuine security incidents from false alarms.</p> <p>Alerts and the underlying detection rules are customisable and tuned to reduce false positives as well as optimising responses.</p> <p>Detections and alerting may use off the shelf tooling and rules as well as custom tooling and / or rules.</p> <p>You continuously monitor for user and system abnormalities indicative of adverse activity generating alerts based on the results of such monitoring.</p> <p>Logs are monitored continuously in near real time.</p> |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

### C1.d Triage of Security Alerts

*You contextualise alerts with knowledge of the threat and your systems, to identify security incidents as well as responding to all alerts appropriately.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                           | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| <p>You do not triage alerts from your detection security technologies (e.g. AV, IDS).</p> <p>You do not categorise alerts and incidents by type and priority / severity level.</p> <p>You do not have Standard Operating Procedures (SOPs) / Playbooks / Runbooks available for use during triage.</p> <p>You do not keep records of triage performed.</p> <p>You do not have a sufficient understanding of normal user or system behaviour to make effective decisions within triage.</p> | <p>You investigate and triage alerts from some security tools and take action.</p> <p>You have created, made available and use when appropriate, Standard Operating Procedures (SOPs) / Playbooks / Runbooks covering the most common use cases. These are regularly reviewed to ensure they remain effective.</p> <p>You perform some triage and actions taken by monitoring and detection personnel are recorded.</p> <p>You categorise alerts and incidents by type and priority / severity level.</p> <p>Your understanding of normal user or system behaviour informs your decision making within triage.</p> | <p>You investigate and triage alerts from all security tools and take action.</p> <p>You have created, made available and use when appropriate, Standard Operating Procedures (SOPs) / Playbooks / Runbooks covering all plausible use cases. These are regularly reviewed to ensure they remain effective.</p> <p>You categorise alerts and incidents by type and priority / severity level.</p> <p>You document all triage related activities performed by monitoring and detection personnel and these are used to drive improvements</p> <p>Triage provides enough information for subsequent activities to be prioritised (e.g. the containment of damaging malware).</p> <p>Your understanding of normal user and system behaviour, and threats, is sufficient for effective decision making within triage.</p> |

### **C1.e Personnel Skills for Monitoring and Detection**

*Monitoring and detection personnel skills and roles, including those outsourced, reflect governance and reporting requirements, expected threats and the complexities of the network or system data they need to use. Monitoring and detection personnel have sufficient knowledge of network and information systems and the essential function(s) they need to protect.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| <p>There are no personnel who perform a monitoring and detection function.</p> <p>Monitoring and detection personnel do not have the correct specialist skills.</p> <p>Monitoring and detection personnel are not capable of reporting against governance requirements.</p> <p>Monitoring and detection personnel have a lack of awareness of the essential function(s) the organisation provides, what assets relate to those functions and hence the importance of the log data and security events.</p> <p>Monitoring and detection personnel have no awareness of other roles or tasks outside of security monitoring and detection that are relevant to the operation of your essential function(s).</p> | <p>Monitoring and detection personnel have some investigative skills and a basic understanding of the data they need to work with.</p> <p>Monitoring and detection personnel can report to other parts of the organisation (e.g. security directors, resilience managers).</p> <p>Monitoring and detection personnel are capable of following most of the required workflow(s).</p> <p>Monitoring and detection personnel are aware of some of the network and information systems and your essential function(s), and can manage alerts relating to them.</p> <p>Monitoring and detection personnel have some understanding of the operational context (e.g. people, processes, network and information systems</p> | <p>You have monitoring and detection personnel who are responsible for the proactive and reactive analysis, investigation and reporting of monitoring alerts including both security and performance.</p> <p>Monitoring and detection personnel have defined roles and skills that cover all parts of the monitoring and investigation process.</p> <p>Monitoring and detection personnel follow policies, processes and procedures that address all governance reporting requirements, internal and external.</p> <p>Monitoring and detection personnel are empowered to look beyond the fixed process to investigate and understand non-standard threats.</p> <p>Monitoring and detection personnel are aware of the network and information</p> |

|                                                                                                                                                         |                                                                                                                                                                                        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|---------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>Monitoring and detection personnel are overwhelmed with the amount of data and alerts they have to work with. Alert / triage fatigue is present.</p> | <p>that support your essential function(s)) to enhance the security monitoring function.</p> <p>Monitoring and detection personnel deal with their workload and cases effectively.</p> | <p>systems and your essential function(s), related assets and can identify and prioritise alerts and investigations that relate to them.</p> <p>Monitoring and detection personnel drive and shape new log data collection and can make effective use of it.</p> <p>Monitoring and detection personnel are capable of following all of the required workflow(s).</p> <p>Monitoring and detection personnel have a sufficient understanding of the operational context (e.g. people, processes, network and information systems that support your essential function) to enhance the security monitoring function.</p> <p>Monitoring and detection personnel deal with their workload and cases effectively as well as identifying areas for improvement.</p> |
|---------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

### **C1.f Understanding User's and System's Behaviour, and Threat Intelligence (within Security Monitoring)**

*Threats to the operation of network and information systems, and corresponding user and system behaviour, are sufficiently understood. These are used to detect cyber security incidents.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| <p>Your organisation has no sources of threat intelligence.</p> <p>You do not evaluate the usefulness of your threat intelligence or share feedback with providers or other users.</p> <p>You have no awareness of the steps necessary to make best use of threat intelligence for security monitoring.</p> <p>Threat intelligence is unreliable and / or is not actioned by the appropriate users or systems in a timely manner.</p> <p>You have no established understanding of what abnormalities to look for that might signify adverse activities.</p> <p>You do not receive updates for all your detection security technologies (e.g. AV, IDS).</p> | <p>You know how effective your threat intelligence is (e.g. by tracking how threat intelligence helps you identify security incidents).</p> <p>Your organisation may use threat intelligence services, but you do not necessarily choose sources or providers specifically because of your business needs, or specific threats in your sector (e.g. sector-based infoshare, software vendors, anti-virus providers, specialist threat intel firms, special interest groups).</p> <p>The user and system abnormalities from past attacks and threat intelligence, on your and other network and information systems, are used to signify adverse activity.</p> <p>You receive regular updates for all of your detection security technologies (e.g. AV, IDS).</p> | <p>You track the effectiveness of your threat intelligence and actively share feedback on the usefulness of Indicators of Compromise (IoCs) and other intelligence with the threat community (e.g. sector partners, threat intelligence providers, government agencies).</p> <p>When using threat intelligence feeds, these have been selected using risk-based and threat-informed decisions based on your business needs and sector.</p> <p>You make relevant, reliable and actionable threat intelligence available to the necessary users and systems promptly.</p> <p>You contextualise threat intelligence and link it to the why and / or how attacks take place for security monitoring.</p> |

|                                                                                                                                        |  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|----------------------------------------------------------------------------------------------------------------------------------------|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>You do not understand normal user and system behaviour sufficiently to be able to use abnormalities to detect adverse activity.</p> |  | <p>You understand normal user and system abnormalities fully, to such an extent that searching for system abnormalities is an effective way of detecting adverse activity (e.g. you fully understand which systems should and should not communicate and when).</p> <p>The user and system abnormalities you monitor for are based on the nature of adverse activities likely to impact network and information systems supporting the operation of your essential function(s).</p> <p>The user and system abnormalities indicative of adverse activity you use are regularly updated to reflect changes in network and information systems supporting your essential function(s) and current threat intelligence.</p> <p>You possess the capability to share threat intelligence (e.g. ways to effectively detect adversaries) with the threat community / defender community (sector partners, threat intelligence providers, government agencies) when required.</p> |
|----------------------------------------------------------------------------------------------------------------------------------------|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## Principle C2 Threat Hunting

*The organisation proactively seeks to detect, within networks and information systems, adverse activity affecting, or with the potential to affect, the operation of essential functions even when the activity evades standard security prevent / detect solutions (or when standard solutions are not deployable).*

### C2.a Threat Hunting

| Not Achieved                                                                                                                                                                                                                        | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                    | All of the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          | All of the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| <p>You do not know the resources required for threat hunting.</p> <p>You do not have access to an effective threat hunting capability.</p> <p>Your threat hunts do not follow any structure and few if any records are created.</p> | <p>You have identified the resources required to perform threat hunting and are able to deploy these, in a timely manner, on an occasional basis.</p> <p>You deploy an effective threat hunting capability but not frequent enough to match the risks posed to network and information systems supporting your essential function(s) (e.g. you perform threat hunts in response to a tip off from a reputable source).</p> <p>Your threat hunts follow pre-determined and documented methods (e.g. hypothesis driven, data driven, entity driven) designed to identify adverse activity not detected by automated detections.</p> | <p>You understand the resources required to perform threat hunting and these are deployed as part of business as usual.</p> <p>You deploy threat hunting resources at a frequency that matches the risks posed to network and information systems supporting your essential function(s).</p> <p>Your threat hunts follow pre-determined and documented methods (e.g. hypothesis driven, data driven, entity driven) designed to identify adverse activity not detected by automated detections.</p> <p>You turn threat hunts into automated detections and alerting where appropriate.</p> <p>You routinely record details of previous threat hunts and</p> |

|  |                                                                     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|--|---------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <p>You document details of threat hunts and post hunt analysis.</p> | <p>post hunt activities. You use these to drive improvements in your threat hunting and security posture.</p> <p>You have justified confidence in the effectiveness of your threat hunts and the threat hunting process is reviewed and updated to match the risks posed to network and information systems supporting your essential function(s).</p> <p>You leverage automation to improve threat hunts where appropriate (e.g. some stages of the threat hunting process are automated).</p> <p>Your threat hunts focus on the tactics, techniques and procedures (TTPs) of threats over atomic IoCs (e.g. hashes, IP addresses, domain names etc).</p> |
|--|---------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## CAF – Objective D – Minimising the impact of cyber security incidents

Capabilities exist to minimise the adverse impact of a cyber security incident on the operation of essential functions, including the restoration of those function(s) where necessary.

### Principle D1 Response and Recovery Planning

*There are well-defined and tested incident management processes in place, that aim to ensure continuity of essential function(s) in the event of system or service failure. Mitigation activities designed to contain or limit the impact of compromise are also in place.*

#### D1.a Response Plan

*You have an up-to-date incident response plan that is grounded in a thorough risk assessment that takes account of network and information systems supporting the operation of your essential function(s) and covers a range of incident scenarios.*

| Not Achieved                                                                                                                                                                                                                                | Partially Achieved                                                                                                                                                                                                                                                                                                                                                                            | Achieved                                                                                                                                                                                                                                                                                                                                                                               |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                            | All the following statements are true                                                                                                                                                                                                                                                                                                                                                         | All the following statements are true                                                                                                                                                                                                                                                                                                                                                  |
| <p>Your incident response plan is not documented.</p> <p>Your incident response plan does not include your organisations identified essential function(s).</p> <p>Your incident response plan is not well understood by relevant staff.</p> | <p>Your incident response plan covers network and information systems supporting your essential function(s).</p> <p>Your incident response plan comprehensively covers scenarios that are focused on likely impacts of known and well understood attacks only.</p> <p>Your incident response plan is understood by all staff who are involved with your organisation's response function.</p> | <p>Your incident response plan is based on a clear understanding of the security risks to network and information systems supporting your essential function(s).</p> <p>Your incident response plan is comprehensive (i.e. covers the complete lifecycle of an incident, roles and responsibilities, and reporting) and covers likely impacts of both known attack patterns and of</p> |

|  |                                                                                                                                                                                                                                                                                                                                     |                                                                                                                                                                                                                                                                                                                                                                                                                          |
|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <p>Your incident response plan is documented and shared with all relevant stakeholders.</p> <p>Your incident response plan is readily accessible, even when your organisations IT systems have been adversely affected by an incident.</p> <p>Your incident response plan is regularly reviewed to ensure it remains effective.</p> | <p>possible attacks, previously unseen.</p> <p>Your incident response plan is documented and integrated with wider organisational business plans and supply chain response plans, as well as dependencies on supporting infrastructure (e.g. power, cooling etc).</p> <p>Your incident response plan is communicated and understood by the business areas involved with the operation of your essential function(s).</p> |
|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

### **D1.b Response and Recovery Capability**

*You have the capability to enact your incident response plan, including effective limitation of impact on the operation of your essential function(s). During an incident, you have access to timely information on which to base your response decisions.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                    | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                         |
| <p>Inadequate arrangements have been made to make the right resources available to implement your response plan.</p> <p>Your response team members are not equipped to make good response decisions and put them into effect.</p> <p>Inadequate back-up mechanisms exist to allow the continued operation of your essential function(s) during an incident.</p> | <p>You understand the resources that will likely be needed to carry out any required response activities, and arrangements are in place to make these resources available.</p> <p>You understand the types of information that will likely be needed to inform response decisions and arrangements are in place to make this information available.</p> <p>Your response team members have the skills and knowledge required to decide on</p> |

|  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|--|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <p>the response actions necessary to limit harm, and the authority to carry them out.</p> <p>Key roles are duplicated, and operational delivery knowledge is shared with all individuals involved in the operations and recovery of the essential function(s).</p> <p>Back-up mechanisms are available that can be readily activated to allow continued operation of your essential function(s), although possibly at a reduced level, if primary network and information systems fail or are unavailable.</p> <p>Arrangements exist to augment your organisation's incident response capabilities with external support if necessary (e.g. specialist cyber incident responders).</p> |
|--|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

**D1.c Testing and Exercising**

*Your organisation carries out exercises to test response plans, using past incidents that affected your (and other) organisation, and scenarios that draw on threat intelligence and your risk assessment.*

| Not Achieved                                                                                                                                                                                                                                                                                                               | Achieved                                                                                                                                                                                                                                                                                                                        |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                           | All the following statements are true                                                                                                                                                                                                                                                                                           |
| <p>Exercises test only a discrete part of the process (e.g. that backups are working), but do not consider all areas.</p> <p>Incident response exercises are not routinely carried out or are carried out in an ad-hoc way.</p> <p>Outputs from exercises are not fed into the organisation's lessons learned process.</p> | <p>Exercise scenarios are based on incidents experienced by your and other organisations or are composed using experience or threat intelligence.</p> <p>Exercise scenarios are documented, regularly reviewed, and validated.</p> <p>Exercises are routinely run, with the findings documented and used to refine incident</p> |

|                                                        |                                                                                                                                                                                                                                 |
|--------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Exercises do not test all parts of the response cycle. | <p>response plans and protective security, in line with the lessons learned.</p> <p>Exercises test all parts of your response cycle relating to your essential function(s) (e.g. restoration of normal function(s) levels).</p> |
|--------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## Principle D2 Lessons Learned

*When an incident occurs, steps are taken to understand its causes and to ensure remediating action is taken to protect against future incidents.*

### **D2.a Post Incident Analysis**

*When an incident occurs, your organisation takes steps to understand its causes, informing appropriate remediating action.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                            | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| <p>You are not usually able to resolve incidents to a root cause or identify the contributing factors within a broader systems context.</p> <p>You do not have a formal process for investigating causes.</p> <p>Investigators form theories early in the process and only seek evidence that affirms their belief.</p> <p>Investigations are solely focused on identifying the person(s) who can be held responsible for the incident.</p> | <p>Post incident analysis is conducted routinely as a key part of your lessons learned activities following an incident.</p> <p>Your post incident analysis is comprehensive, considering organisational factors (e.g. policies, processes and procedures), technical factors (e.g. system design, vulnerabilities), human factors (e.g. training, security culture) and any changes to threat.</p> <p>All relevant incident data is made available to the analysis team to perform post incident analysis.</p> <p>Your analysis considers what could have happened under plausible, alternative circumstances (e.g. 'what if' / 'if only' scenarios).</p> |

## D2.b Using Incidents to Drive Improvements

*Your organisation uses lessons learned from incidents to improve your security measures.*

| Not Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | Achieved                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| At least one of the following statements is true                                                                                                                                                                                                                                                                                                                                                                                                                                   | All the following statements are true                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| <p>Following incidents, lessons learned are not captured or are limited in scope.</p> <p>Improvements arising from lessons learned following an incident are not implemented or not given sufficient organisational priority.</p> <p>Changes are made as a 'knee jerk' reaction to an incident without proper analysis and testing to ensure the change is appropriate.</p> <p>You wait until a severe or high-profile incident has occurred before you take steps to improve.</p> | <p>You have a documented incident review process / policy which ensures that lessons learned from each incident, including near misses, are identified, captured, and acted upon.</p> <p>Lessons learned cover issues with reporting, roles, governance, skills and organisational policies, processes and procedures as well as technical aspects of network and information systems.</p> <p>You use lessons learned to improve security measures, including updating and retesting response plans when necessary.</p> <p>Security improvements identified as a result of lessons learned are prioritised, with the highest priority improvements completed promptly.</p> <p>Analysis is fed to senior management and incorporated into risk management and continuous improvement.</p> <p>Your organisation maximises the lessons learned by using the analysis into 'what if' / 'if only' scenarios.</p> <p>Your organisation learns from reported incidents in your sector and the wider national infrastructure.</p> |